



Detecting and Preventing Data Exfiltration



Contributors:

Professor Awais Rashid, Dr. Rajiv Ramdhany, Matthew Edwards, Sarah Mukisa Kibirige, Dr. Ali Babar, Professor David Hutchison, Security Lancaster, Lancaster University, UK

Dr. Ruzanna Chitchyan, University of Leicester, UK



Academic Centre of Excellence in Cyber Security Research



The Need for Data-Centric Cyber Security

The need to meet organisational and business challenges such as increased productivity, lowered costs and customer satisfaction has driven organisations to break the traditional 'silo' infrastructure model as they try to improve efficiency, engage more with customers and collaborate closely with partner organisations. In the process, organisations have embraced cultures where employees work anytime, anywhere. They have adopted the use of informatics and social business models for closer collaboration with business partners and with their customer base. Further, the need to engage with customers and other service-providers globally has led to the rapid adoption of cloud-based services and virtualisation. For organisations to rise to these challenges, their IT infrastructures have undergone significant transformations in terms of complexity and heterogeneity.

For instance, opening up the infrastructure through internet- and web-based interfaces to support employee mobility and interactions with other organisations (as part of a supply chain, Software as a Service) has resulted in more entry points that can be targeted for attack by cyber criminals. An organisation's IT infrastructure is, in essence, often a heterogeneous patchwork of systems and technologies procured from third-party providers which can be harbingers of latent vulnerabilities. As system procurers have little control on the design of and the security controls built into sub-systems, they can only be partially trusted at best. Such partially-trusted settings are not an exception but have become the norm in modern business settings. As a result of this, the cyber-security model where perimeter defences maintain a bastion of control over an organisation's network (and crucially, its data assets), no longer suffices for protection.

A significant number of data breach incidents (US retailer Target data theft, Dexter malware campaigns, Neiman Marcus data breach, to mention but a few) point to organised criminal gangs as a new breed of cyber crime perpetrators who actively seek

to steal data from organisations for monetary gains. Advanced Persistent Threats (APTs) and nation state actors also list among this new breed of sophisticated perpetrators, whether it is for the theft of intellectual property for financial/ competitive gain or targeted attacks on critical infrastructure for strategic and economic motives. The Stuxnet, Flame, Aurora and Duqu attack campaigns are examples of the virulence of the new threats and the level of sophistication seen from this group of attackers.

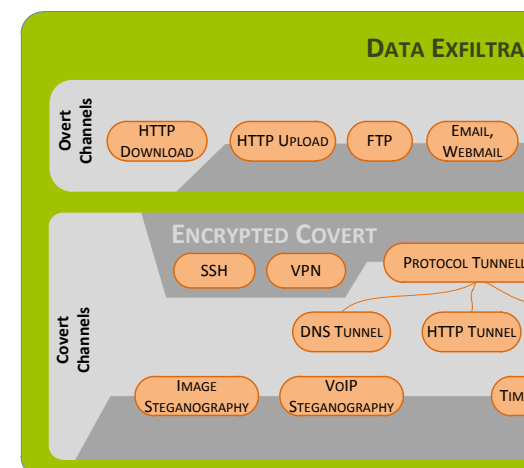
In this new security landscape, the perimeter defence model is now dead. Data (whether it is personalised information, intellectual property or trade secrets), which counts as an organisation's most valuable asset, can no longer be protected by perimeter defences (such as firewalls, and intrusion detection and prevention systems) alone. Data exfiltration, whereby an attacker having established presence on an organisation's network can filter data out of the system through a variety of means, is now a very potent threat. Defences today need to be data-centric and embody strategies to detect, prevent and mitigate data exfiltration attacks.

This executive summary provides an overview of typical data exfiltration means, counter measures and their effectiveness as well as key trends and patterns that may be indicative of data exfiltration from an organisation. It is aimed as a guide that will enable your organisations to benchmark itself against the state-of-the-art and state-of-the-practice of dealing with data exfiltration threats. Such a comparison can reveal the areas where the organisation needs to improve its knowledge, expertise, competencies, technological innovation to either identify and thwart or recover with minimum loss from a data exfiltration attempt. The key message here is that the weapons in an attacker's arsenal are diverse and sophisticated attackers such as APTs are not limited to using typical channels to extract data from organisational networks. They have the capability, motivation and resources to use more advanced channels. Security measures in an organisation, therefore, need to account for these various data exfiltration modes.

Data Exfiltration Methods

Technical methods for extracting data from an organisation's systems range from those commonly seen in attacks to niche vectors and cutting-edge methods for covertly moving information past current detection systems. These methods largely fall into two categories: those using overt channels and those making use of covert channels. Overt channels are the ones that are generally used by any computer user wishing to transfer files between locations. This makes such vectors obvious targets for scrutiny, but also means that corporate networks generally provide for some freedom in their use. In contrast, covert channels, such as encryption, steganography, etc., are used by attackers to evade the detection of network-based monitoring by concealing the data they are removing.

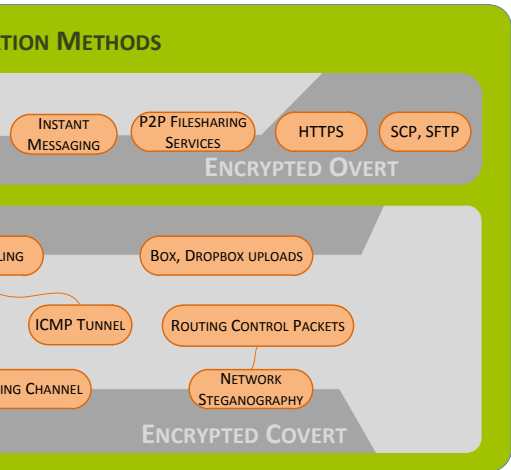
Typical data exfiltration scenarios involve the attacker establishing a Command and Control (C2) connection to remotely control a compromised computer for stealing data or for using it as a pivot point to compromise other host computers. This entails the attacker infiltrating the host computer by exploiting security vulnerabilities (including the human element) in the organisation. For instance, a phishing email such as one containing weaponised MS Office documents or Adobe Acrobat PDFs, or web links to a compromised web site (for drive-by-downloads) could be used to entice an employee to infect his/her computer with a virus that installs a backdoor. Using this backdoor/remote access, attackers can either steal data directly or install malware with specialised functionality (for example, rootkits, key loggers, network sniffers, memory scrapers) to search and exfiltrate sensitive data. Particular exfiltration tactics and



Detecting Data Exfiltration

methods are used based on the scale, duration, complexity and degree of covertness of the attack and suspected security defences in place. In a typical 'grab-and-run' scenario like the RSA data breach, attackers favour speed over covertness and will exfiltrate data over high-bandwidth channels such as FTP, email/web mail, Internet Messaging protocols or HTTP. HTTP channels would have the advantage of appearing as innocuous web sessions and pass unimpeded though the network's perimeter firewall.

If the organisation adheres to some security-compliance standards (for example, PCI compliance for payment card data processors), then one or more layers of encryption can be applied to these channels to confuse the suspected filters in place or an attempt made to evade them via encrypted channels (SSH, HTTPS or VPN). Other exfiltration attacks may span over months (like in the Heartland payment card data breach or the Nitro chemical industry exfiltration attack) inciting the attackers to prioritise attack stealth, exfiltration covertness and periodic exfiltration over aggression and speed. Even then, the exfiltration methods available for covert and long-spanning data theft are numerous. Uploads to cloud storage services such as Box.net, DropBox, Google Drive and the like, remain a favourite among attackers to blend stolen data with normal network traffic (if usage of such services is permitted in the organisation). Protocol tunnelling, steganography and timing channels are less likely to be monitored and offer the degree of covertness required for long-lasting data theft campaigns. Not many organisations are aware that data can be exfiltrated via a DNS tunnel, for instance or that tools to set up DNS tunnels are readily available to even novice hackers.



Organisations can counter the threat of data exfiltration from their systems by utilising a range of methods including those for detecting on-going attempts as well as ones for identifying which people or system components were involved in a breach after the event. Timely detection of exfiltration attempts can enable prevention, while retroactive identification of leaks can help an organisation repair the confidentiality of its systems and prevent recurring damage as well as determine impact by ascertaining specifics of loss.

Of course, a definitive checklist is not possible or feasible given the diversity of security needs and security postures acceptable to different organisations. However, Table 1 provides a helpful guide to decide which solutions enable detection of particular data exfiltration methods. The table can be used to tailor an organisation's response to potential data exfiltration attempts. Known overt channels (e.g. HTTP, FTP, IM, P2P, Email/Webmail) are high-risk channels that can be monitored through the deployment of filters at a channel-specific proxy or gateway (e.g. HTTP proxy or email proxy). For example, filters for these channels are configured as content-matching rules/signatures that allow files or protocol messages to be blocked on a positive match. Unknown overt channels, on the other hand, are overt channels which are not known to an organisation and therefore not monitored i.e. there are no filters in place to

block data being exfiltrated via these channels. Encrypted channels use readily available encryption schemes such as SSL/TLS to obfuscate sensitive data and thwart the filters scanning traffic at the network boundary.

The deployment of HTTP, FTP, IM, P2P and email filters is a necessity to detect data theft across common exfiltration channels. If appropriate content analysers are in place, they will use rules/signature-matching to detect sensitive data. However, such filters can be defeated by encryption or theft via protocol tunnels or steganographic transfer. Monitoring network traffic by inspecting data packets or observing traffic patterns offers a broader level of protection. Anomalous data transfers (encrypted or not) to suspect Internet destinations can be detected and terminated using network monitoring tools. Host-level detection mechanisms are equally important to catch some exfiltration attempts. Tools for analysing and logging access to computers/servers (and their systems) can trigger alerts on particular patterns of activity e.g. malware installed, sensitive files accessed or databases read. Detecting an exfiltration attack is one part of the problem; detecting which parties or IT system components were involved in the data breach is another. A number of techniques (including watermarking of data files) can thus be used to perform leakage flow analysis and identify weaknesses in the infrastructure or in a trust chain of data-handling agents.

Exfiltration Detection	Known Channel Inspection	Network Monitoring	Host Access Analysis/Logging	Leakage Flow Analysis (Post Hoc)	Digital Watermarking (Post Hoc)
Known Overt: HTTP, FTP, IM, P2P, Email/Webmail	✓	✓	✓	✓	✓
Unknown Overt: HTTP, FTP, IM, P2P, Email/Webmail	✗	✓	%	%	✓
Encrypted: SSH, SCP, SFTP, HTTPS, VPN	%	%	✓	✓	✓
Protocol Tunnelling: e.g. HTTP, DNS, ICMP Tunnels	%	✓	✓	%	✗
Steganography: Image, Network or VoIP Steganography	%	%	✓	✓	✓
Timing Channels	✗	✗	✓	✓	✓
Steganography + Encryption	✗	✗	✓	✓	✓

Table 1: The coverage of common approaches to exfiltration detection. A ✓ indicates this method usually detects exfiltration attempts of this type, a % indicates the method can be made to cover this threat, or partially covers this threat, and a ✗ indicates this threat is not covered.

Preventing and Mitigating Data Exfiltration

Prevention and mitigation systems are distinguished from detection systems in that while some systems for the detection of exfiltration can be used to prevent it, not all approaches to prevention will alert the owner that exfiltration has been attempted. As with detection measures, a definitive checklist of preventive measures is not possible or feasible given the varying needs and business contexts in which different organisations operate. However, Table 2 provides a helpful guide to decide which prevention and mitigation approaches are more suited to countering particular types of exfiltration methods. The table can be an aid to identifying suitable preventive measures as part of an organisation's information security and risk management strategy.

Data Loss Prevention tools are examples of actuated detection systems that can be configured to detect unauthorised data transfers based on rules or signatures for content-matching. Upon detection, they can then automatically or semi-

automatically block transfers they consider suspicious. Similarly rogue data connections can be detected and terminated by network monitors. Another aspect of exfiltration prevention, however, concerns defining and enforcing security policies with regards to granting and maintaining access to sensitive data. Solutions exist for policy enforcement whether locally or across recipients of sensitive data to prevent the occurrence of data leaks. Other preventive mechanisms to thwart exfiltration include self-protecting data where a software layer implementing corporate security policy can automatically encrypt data before transfer and storage. Due to the rising use of virtual machines or VMs (in cloud-computing, for instance) for handling sensitive data, a possible threat is where malicious agents have access to the physical machine (the hypervisor) running critical software for organisations. To counter attempts by attackers to extract data by parsing memory at the VM's hypervisor, low-level defences such as mechanisms to isolate co-hosted VMs and hide data from the attacker's view have been proposed.

Exfiltration Prevention and Mitigation	Actuated Detection Systems	Security Policy Tools	Self-Protecting Data	Low-Level Snooping Defences
Known Overt: HTTP, FTP, IM, P2P, Email/Webmail	✓	✓	✓	✓
Unknown Overt: HTTP, FTP, IM, P2P, Email/Webmail	%	%	%	%
Encrypted: SSH, SCP, SFTP, HTTPS, VPN	%	✓	✓	✓
Protocol Tunnelling: e.g. HTTP, DNS, ICMP Tunnels	%	✓	✓	✓
Steganography: Image, Network or VoIP Steganography	%	✓	✓	✓
Timing Channels	X	✓	✓	✓
Steganography + Encryption	X	✓	✓	✓

Table 2: The coverage of common approaches to exfiltration prevention. A ✓ indicates this method usually prevents exfiltration attempts of this type, a % indicates the method can be made to cover this threat, or partially covers this threat, and a X indicates this threat is not covered.

Key Message

In the modern digital society, 'data' is one of the biggest and most valuable commodities. It is, therefore, a key motivator for a number of cyber attacks, be it to gain access to personal data, financial information or intellectual property. At the same time, the complexity arising from modern business settings, new technologies and resulting modes of work lead to an increase in the cyber attack surface of an organisation and, consequently, a higher risk of data exfiltration.

Advanced Persistent Threats (APTs) and attackers motivated by industrial espionage are persistent and return again and again in order to achieve their objective. The best way to achieve resilience in this landscape is to assume that at some point a breach in the security measures will take place. This enables identification and deployment of mechanisms that can enable cyber security personnel and systems in an organisation to detect, stop or at least disrupt data leakage following such a breach. This executive summary, and the accompanying detailed report, is aimed at helping organisations to develop such resilience. It articulates the various data exfiltration vectors – whether it is data at rest, in use or in motion. Furthermore, it not only provides guidance on detecting, mitigating and preventing data exfiltration attempts but also how to recover if the inevitable happens and these counter measures are evaded by sophisticated attackers such as APTs. Resilience to data exfiltration threats can only be achieved through such a holistic and cohesive approach.